

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Credential Handling Policy One-Pager

One page on how agents receive, store, and never transmit credentials. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

CREDENTIAL HANDLING POLICY ONE-PAGER

FOR AI AGENTS IN PRODUCTION [ORGANIZATION NAME] [TEAM NAME] [EFFECTIVE DATE]
[REVISION NUMBER] [DOCUMENT OWNER: NAME/TITLE]

1. PURPOSE

This policy establishes **strict controls** for credential handling by AI agents in production environments to: - Prevent unauthorized access to sensitive systems. - Ensure compliance with **[LEGAL/JURISDICTIONAL FRAMEWORK]** (e.g., GDPR, CCPA, HIPAA, SOC 2). - Mitigate risks of credential theft, leakage, or misuse. - Maintain auditability of all credential-related actions.

Scope: Applies to all AI agents, automation workflows, and third-party integrations accessing **[BRACKETED CAPS: SPECIFY SYSTEMS/APPS]** (e.g., databases, payment gateways, CRM platforms).

2. POLICY STATEMENTS

2.1 Credential Classification & Protection

Credential Type	Protection Level	Storage Requirements	Encryption Standard
API Keys	[HIGH/MEDIUM/LOW]	[BRACKETED CAPS: STORAGE METHOD] (e.g., encrypted secrets manager, HSM)	[AES-256/OTHER]
Service Accounts	[HIGH/MEDIUM/LOW]	[BRACKETED CAPS: STORAGE METHOD]	[AES-256/OTHER]
Database Credentials	[HIGH/MEDIUM/LOW]	[BRACKETED CAPS: STORAGE METHOD]	[AES-256/OTHER]
SSH Keys	HIGH	[BRACKETED CAPS: STORAGE METHOD] (e.g., vault with MFA)	[RSA-4096/OTHER]
OAuth Tokens	[HIGH/MEDIUM/LOW]	[BRACKETED CAPS: STORAGE METHOD] (short-lived preferred)	[JWT-SIGNATURE-ALG]

Note: All credentials must be **rotated every [BRACKETED CAPS: ROTATION INTERVAL]** (e.g., 90 days for API keys).

2.2 Access Control & Permissioning

- Principle of Least Privilege:** AI agents must have **minimum required permissions** (e.g., read-only for analytics agents, write for billing systems).
- Permissioning Workflow:**
- [BRACKETED CAPS: REQUESTER ROLE]** submits a **credential request form** via **[BRACKETED**

CAPS: APPROVAL TOOL].

- [BRACKETED CAPS: APPROVAL ROLE] (e.g., DevOps, Security) validates:
 - Justification for access.
 - Scope of permissions.
 - Compliance with [BRACKETED CAPS: ORGANIZATIONAL STANDARDS].
 - Approval triggers **automated credential issuance** to [BRACKETED CAPS: SECRETS MANAGER].
 - **Revocation:** Credentials must be **immediately revoked** if:
 - Access is no longer needed.
 - [BRACKETED CAPS: INCIDENT TRIGGER] occurs (e.g., credential exposure).
 - [BRACKETED CAPS: AUTO-REVOCATION SCHEDULE] expires.
-

2.3 Audit & Monitoring

- **Real-Time Logging:**
 - All credential access attempts must be logged to [BRACKETED CAPS: LOGGING SYSTEM] with:
 - Timestamp, agent ID, action (e.g., read, write), success/failure.
 - [BRACKETED CAPS: RETENTION PERIOD] (e.g., 1 year).
 - **Alerting Thresholds:**
 - **Failed login attempts** > [BRACKETED CAPS: THRESHOLD] (e.g., 3) -> Trigger [BRACKETED CAPS: ALERT CHANNEL].
 - **Unusual access patterns** (e.g., geolocation mismatch) -> Escalate to [BRACKETED CAPS: SECURITY TEAM].
 - **Regular Audits:**
 - [BRACKETED CAPS: AUDITOR ROLE] conducts quarterly reviews of:
 - Unused credentials.
 - Permission creep.
 - Compliance with this policy.
-

2.4 Incident Response

Incident Type	Detection	Containment	Notification	Recovery
Credential Exposure	[BRACKETED CAPS: DETECTION TOOL]	Revoke affected credentials; isolate agent.	Notify all [BRACKETED CAPS: SECURITY TEAM] and [BRACKETED CAPS: COMPLIANCE OFFICER].	Rotate credentials; investigate root cause.
Unauthorized Access	[BRACKETED CAPS: DETECTION TOOL]	Terminate session; disable agent.	Escalate to [BRACKETED CAPS: INCIDENT RESPONSE TEAM].	Conduct forensic analysis; update access controls.
Policy Violation	[BRACKETED CAPS: AUDIT LOG]	Escalate to [BRACKETED CAPS: COMPLIANCE TEAM].	Document in [BRACKETED CAPS: INCIDENT TRACKER].	Remediate; retrain responsible party.

Post-Incident Review: - [BRACKETED CAPS: LEAD TIME] days after resolution, conduct a lessons-learned meeting with: - [BRACKETED CAPS: TEAMS INVOLVED]. - Update [BRACKETED CAPS: POLICY DOCUMENT] as needed.

2.5 Cost & Resource Controls

- **Budget Alerts:**
 - If credential-related costs (e.g., API calls, storage) exceed [BRACKETED CAPS: MONTHLY BUDGET], trigger alert to [BRACKETED CAPS: FINANCE TEAM].
 - **Agent Lifecycle Costs:**
 - [BRACKETED CAPS: COST MONITORING TOOL] tracks:
 - Credential issuance/revocation costs.
 - Storage fees for secrets.
 - **Cap:** No single agent may exceed [BRACKETED CAPS: MAX ALLOWED COST] without approval.
-

3. ROLES & RESPONSIBILITIES

Role	Responsibilities
[BRACKETED CAPS: DEVELOPER ROLE]	Follows credential handling procedures; reports violations.
[BRACKETED CAPS: SECURITY TEAM]	Enforces access controls; investigates incidents.
[BRACKETED CAPS: COMPLIANCE OFFICER]	Ensures policy alignment with [BRACKETED CAPS: REGULATORY REQUIREMENTS].
[BRACKETED CAPS: OPERATIONS TEAM]	Manages secrets manager; rotates credentials on schedule.
[BRACKETED CAPS: REQUESTER'S MANAGER]	Approves exceptions to least-privilege rules.

4. COMPLIANCE & ENFORCEMENT

- **Non-Compliance:** Violations result in:
 - Immediate revocation of agent access.
 - [BRACKETED CAPS: DISCIPLINARY ACTION] (e.g., training, termination).
 - Reporting to [BRACKETED CAPS: COMPLIANCE AUTHORITY] if applicable.
 - **Training:** All [BRACKETED CAPS: AFFECTED ROLES] complete [BRACKETED CAPS: TRAINING PROGRAM] annually.
-

5. ADOPTION NOTES

5.1 Implementation Checklist

- [] [BRACKETED CAPS: SECRETS MANAGER] configured with [BRACKETED CAPS: ENCRYPTION METHOD].
- [] [BRACKETED CAPS: LOGGING SYSTEM] integrated with [BRACKETED CAPS: SIEM TOOL] (e.g., Splunk, Datadog).

- ☐ [BRACKETED CAPS: APPROVAL WORKFLOW] tested with [BRACKETED CAPS: TEST CREDENTIALS].
- ☐ [BRACKETED CAPS: INCIDENT RESPONSE PLAYBOOK] updated to include credential-related steps.
- ☐ [BRACKETED CAPS: TRAINING RECORDS] maintained for all [BRACKETED CAPS: TRAINED ROLES].

5.2 Buyer-Fillable Field Validation

[x] Every [BRACKETED CAPS] placeholder is documented in **Section 5.1** above. [x] All fields align with [BRACKETED CAPS: ORGANIZATIONAL STANDARDS]. [x] No placeholder uses non-standard formatting (e.g., [Insert ...]). [x] [EFFECTIVE DATE] and [REVISION NUMBER] are set for tracking. [x] [DOCUMENT OWNER] is assigned for updates.

Approval: [APPROVING AUTHORITY NAME/TITLE] [DATE]

Version History: | Revision | Date | Changes | Approver |

Initial release	[DOCUMENT OWNER]	[NEXT REV]	[FUTURE DATE]	[DESCRIBE CHANGES]	[APPROVING AUTHORITY]	1.0	[EFFECTIVE DATE]
-----------------	------------------	------------	---------------	--------------------	-----------------------	-----	------------------

End of Document

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com